



Pixel Bait

Versión	1.0 Fase 1
Fecha	Lunes 15 de junio
Metodología	Cascada (Waterfall)
Autor	Product Manager(junior)
Fecha límite de entrega	Domingo 21 de junio
Estado	Pendiente de aprobación formal del Stakeholder



<https://github.com/Ese-peque-ingel/pixelbait.git>



Contenido

1.Introducción y Propósito del documento	4
1.1Contexto del proyecto	4
2. Objetivos del proyecto	4
2.1 Objetivo General	4
2.2 Objetivos Específicos	5
3. Alcance del proyecto	5
3.1 Dentro del Alcance (In - Scope)	5
3.2 Fuera del Alcance (Out-of Scope)	6
4.Requisitos Funcionales	6
4.1 Módulo de Onboarding	6
4.2 Módulo de Escaneo y Análisis	7
4.3 Módulo de Navegador Integrado	7
4.4 Módulo de Historial y opciones	8
4.5 Sitio Web Estático Institucional	8
5.Requisitos No funcionales	9
6.Restricciones y supuestos	10
6.1 Restricciones	10
6.2 Supuestos	10
7.Matriz de Riesgos	11
8.Criterios de Aceptación de Alto Nivel	12
10.Proposito	13
11.Arquitectura del sistema	13
12. Modelado de datos (Almacenamiento Local)	14
13.Flujo principal: Escaneo	15
15.Stack Tecnológico	16
15. Flujos principales	17
15.1 Flujo de Onboarding (RF-01 a RF-03)	17
15.2 Flujo de Escaneo y Clasificación (RF-04 a RF-06)	17

15.3 Flujo de Navegación Controlada y Detección de Anomalías (RF-07 a RF-11)	18
16. Especificación de API – Peticiones a Virus Total	18



Proyecto: Analizador de QR “Pixel Bait” open source.

1.Introducción y Propósito del documento

Este documento constituye la especificación formal de requisitos (BRD/PRD) del proyecto **"Pixel Bait"** y representa el cierre de la Fase 1 del ciclo de vida Cascada (Waterfall). Su propósito es establecer, de manera exhaustiva y no ambigua, el alcance, las funcionalidades, las restricciones y los criterios de aceptación del sistema, sirviendo como línea base contractual para las fases posteriores de Diseño, Implementación, Verificación y Mantenimiento.

Bajo el modelo Cascada, este documento debe ser revisado y aprobado formalmente antes de iniciar la Fase 2 (Diseño del Sistema). Cualquier modificación posterior a su aprobación deberá tramitarse mediante un procedimiento formal de Solicitud de Cambio (Change Request), evaluando su impacto en alcance, tiempo y costo.

1.1 Contexto del proyecto

Pixel Bait es un proyecto de naturaleza académica, desarrollado como requisito para la liberación de prácticas profesionales. Esta naturaleza académica condiciona directamente las restricciones de presupuesto, el modelo de desarrollo (basado en ingeniería de prompts con asistencia de inteligencia artificial) y los criterios de éxito del proyecto, los cuales se detallan en las secciones correspondientes.

2. Objetivos del proyecto

2.1 Objetivo General

Desarrollar una aplicación móvil para Android que permita a los usuarios escanear códigos QR y analizar de forma preventiva si la URL contenida representa una amenaza de seguridad (malware, phishing o comportamiento malicioso), antes de que el usuario acceda al recurso.

2.2 Objetivos Específicos

1. Integrar el motor de análisis de URLs de VirusTotal mediante API, utilizando una clave provista por cada usuario final.
2. Clasificar el resultado del análisis en tres niveles de riesgo (Alto, Medio, Seguro) con reglas de negocio definidas y verificables.
3. Proveer un navegador integrado en la aplicación que monitoree comportamientos anómalos post-escaneo (descargas no consentidas, acceso a cámara, solicitud de geolocalización) y bloquee/liste en negro las URLs que los presenten.
4. Mantener un historial local de escaneos con una vigencia de 7 días.
5. Proteger la clave API del usuario mediante cifrado simétrico AES-256.
6. Publicar un sitio web estático institucional que sirva como canal de soporte, descarga y presentación del proyecto.
7. Cumplir con el criterio de éxito definido por el stakeholder: que el software realice los análisis de forma correcta, dentro del plazo académico establecido.

3. Alcance del proyecto

El stakeholder ha optado formalmente por la alternativa de

El stakeholder ha optado formalmente por la alternativa de **alcance completo**, incluyendo la totalidad de los componentes descritos en esta sección, con fecha de entrega el 28 de julio de 2026. Esta decisión ha sido registrada como un **riesgo alto aceptado** (ver Sección 7 — Matriz de Riesgos).

3.1 Dentro del Alcance (In - Scope)

- Aplicación móvil nativa/híbrida para Android únicamente (no se contempla iOS).
- Flujo de onboarding: términos y condiciones, permisos de cámara, configuración de API Key de VirusTotal.
- Escáner de códigos QR mediante cámara del dispositivo.
- Integración con la API de VirusTotal (clave provista por cada usuario final).
- Motor de clasificación de riesgo (Alto / Medio / Seguro) según reglas de negocio definidas en la Sección 4.
- Navegador integrado en la aplicación con detección de comportamiento anómalo y bloqueo/lista negra de URLs.

- Historial local de escaneos con expiración automática a los 7 días.
- Pantalla de opciones: visualización de términos y condiciones, y personalización de tema visual (paleta azul marino / violeta, según identidad de marca).
- Cifrado AES-256 de la API Key almacenada localmente.
- Sitio web estático institucional con las 6 secciones especificadas: Hero, Cómo Funciona, Historia, Misión/Visión, Equipo, Footer.

3.2 Fuera del Alcance (Out-of Scope)

- Versión para iOS o cualquier otra plataforma distinta a Android.
- Backend o almacenamiento en la nube para el historial de escaneos (el historial es exclusivamente local).
- Provisión de una API Key de VirusTotal propia del proyecto; cada usuario gestiona la suya.
- Hosting pagado, dominio propio de pago, o servicios en la nube con costo recurrente para el sitio web estático (debe resolverse con alternativas de nivel gratuito).
- Soporte técnico post-entrega remunerado, más allá del periodo académico de prácticas profesionales.
- Monetización, publicidad o modelo de no negocio comercial.

4.Requisitos Funcionales

A continuación se presenta la matriz de requisitos funcionales, con trazabilidad al documento funcional original provisto por el stakeholder.

4.1 Módulo de Onboarding

ID	Requisito	Detalle
RF-01	Términos y condiciones	Al primer inicio, mostrar T&C con botón "Siguiende" para continuar.
RF-02	Permisos de cámara	Tras aceptar T&C, solicitar permiso de cámara con botón "Siguiende".

RF-03	Configuración de API Key	Solicitar API Key de VirusTotal. Si el usuario no la posee, mostrar opción de ayuda que redirige al sitio web oficial de Pixel Bait. El botón "Siguiete" solo se habilita al ingresar una clave válida.
-------	--------------------------	---

4.2 Módulo de Escaneo y Análisis

ID	Requisito	Detalle
RF-04	Escáner de QR	Disponible una vez configurada la API Key. Utiliza la cámara del dispositivo.
RF-05	Clasificación de riesgo	Alto riesgo: 3 o más motores clasifican la URL como "malicious". Riesgo Medio: 1-2 motores secundarios marcan "suspicious" o "malicious". Seguro: pasa todos los filtros estándar sin patrones de comportamiento anómalo.
RF-06	Presentación del resultado	Card visual indicando el nivel de criticidad de la URL analizada.

4.3 Módulo de Navegador Integrado

ID	Requisito	Detalle
RF-07	Apertura controlada	Tras el análisis, el usuario puede abrir la URL en un navegador integrado en la app (no el navegador externo del sistema).
RF-08	Monitoreo de descargas	Detectar si la página intenta descargar archivos sin consentimiento del usuario.

RF-09	Monitoreo de cámara	Detectar apertura de cámara sin consentimiento del usuario.
RF-10	Monitoreo de geolocalización	Detectar solicitudes de ubicación del usuario.
RF-11	Bloqueo y lista negra	Si se detecta cualquiera de las anomalías anteriores, el navegador bloquea y añade la URL a una lista negra local.

4.4 Módulo de Historial y opciones

ID	Requisito	Detalle
RF-12	Historial local	Registro de escaneos realizados, almacenado localmente en el dispositivo, con vigencia máxima de 7 días.
RF-13	Consulta de T&C	Apartado de Opciones permite visualizar nuevamente los términos y condiciones.
RF-14	Personalización visual	Apartado de Opciones permite alternar entre tema de la paleta de marca (azul marino / violeta) y tema oscuro (negro).

4.5 Sitio Web Estático Institucional

El sitio web deberá incluir, de forma obligatoria, las siguientes seis secciones:

8. Hero Section: nombre, eslogan, problema que resuelve, botón CTA hacia descarga/tutorial.
9. Cómo Funciona / Primeros Pasos: video tutorial embebido, lista de 3-4 pasos, badges de descarga (Google Play).
10. Historia / Año de creación: narrativa breve del origen del proyecto.

11. Misión y Visión: propósito actual y metas futuras.
12. El Equipo: fotografías, roles y enlaces profesionales de los creadores.
13. Footer: contacto, redes sociales, políticas de privacidad, aviso de derechos de autor.

5.Requisitos No funcionales

Categoría	Requisito
Seguridad	La API Key de VirusTotal debe almacenarse cifrada mediante AES-256 (cifrado simétrico).
Plataforma	Compatibilidad exclusiva con Android (versión mínima a definir en Fase 2).
Retención de datos	Los registros del historial de escaneos deben purgarse automáticamente tras 7 días.
Almacenamiento	Todo el almacenamiento de historial y configuración es local; no se contempla sincronización en la nube.
Usabilidad	El flujo de onboarding debe ser lineal y secuencial, sin permitir saltar pasos obligatorios (T&C, permisos, API Key).
Disponibilidad del sitio web	Debe alojarse en un servicio de nivel gratuito, dado que el presupuesto no contempla hosting de pago.

6. Restricciones y supuestos

6.1 Restricciones

- Presupuesto: \$1,000 MXN, destinados exclusivamente a la cuota única de registro de desarrollador en Google Play Console.
- Tiempo: fecha límite improrrogable el 28 de julio de 2026 (aprox. 4 semanas desde el inicio de la documentación).
- Recursos humanos: no existe un equipo de desarrollo dedicado; el desarrollo se ejecuta mediante ingeniería de prompts con asistencia de IA.
- Plataforma: exclusivamente Android; no se contemplan recursos para desarrollo iOS.
- Presupuesto de infraestructura web: nulo más allá de la cuota de Play Store; el sitio web debe usar alternativas gratuitas de hosting/dominio.

6.2 Supuestos

- Se asume que cada usuario final posee o puede generar gratuitamente su propia API Key de VirusTotal (nivel gratuito, con límites de tasa conocidos, p. ej. ~4 solicitudes/minuto).
- Se asume que el stakeholder validará y probará manualmente el código generado mediante IA antes de cada entrega parcial, dado que no existe un equipo de QA dedicado.
- Se asume acceso a una cuenta de Google Play Console vigente o la posibilidad de adquirirla dentro del presupuesto asignado.

7. Matriz de Riesgos

Riesgos identificados durante la Fase 1, con su probabilidad, impacto y tratamiento. Los riesgos marcados como "Aceptado" han sido revisados con el stakeholder, quien decide proceder pese a la advertencia formal del Product Manager.

ID	Riesgo	Prob.	Impacto	Tratamiento
R-01	Alcance completo (app + navegador integrado + sitio web) no se complete para el 28 de julio.	Alta	Alto	Aceptado por el stakeholder. Mitigación sugerida en Fase 3: priorizar entregas incrementales internas aunque la metodología sea Cascada.
R-02	Código generado por IA (ingeniería de prompts) contenga errores de seguridad no detectados, especialmente en el módulo de cifrado AES-256 y en el navegador integrado.	Media-Alta	Alto	Mitigar en Fase 4 con plan de pruebas reforzado y revisión manual de los módulos críticos de seguridad.
R-03	Límite de tasa de la API gratuita de VirusTotal (por usuario) degrade la experiencia de escaneo en uso intensivo.	Media	Medio	Documentar la limitación en el sitio web / ayuda de la app; no mitigable dentro del alcance y presupuesto actuales.
R-04	Hosting gratuito del sitio web presente limitaciones (dominio genérico, sin HTTPS personalizado, etc.).	Media	Bajo	Aceptar limitación; seleccionar proveedor gratuito confiable en Fase 2/3 (ej. GitHub Pages, Vercel, Netlify).
R-05	Ambigüedad en definición de "análisis correcto" (criterio de aceptación) genere disputas al cierre del proyecto.	Baja	Medio	Mitigado en este documento mediante criterios de aceptación explícitos (Sección 8).

8. Criterios de Aceptación de Alto Nivel

El proyecto se considerará exitoso, a efectos de esta fase, cuando se cumplan de forma verificable los siguientes criterios:

14. La aplicación instalada en un dispositivo Android permite completar el flujo de onboarding (T&C → permisos de cámara → API Key) sin errores.
15. Al escanear un código QR válido, la aplicación consulta la API de VirusTotal y clasifica el resultado en Alto Riesgo, Riesgo Medio o Seguro, conforme a las reglas definidas en RF-05, mostrando el resultado correcto para al menos un caso de prueba de cada categoría.
16. El navegador integrado detecta y bloquea correctamente al menos un escenario de prueba por cada anomalía definida (descarga no consentida, acceso a cámara, solicitud de ubicación).
17. El historial de escaneos se almacena localmente y los registros con más de 7 días de antigüedad dejan de mostrarse.
18. La API Key almacenada no es legible en texto plano al inspeccionar el almacenamiento local del dispositivo (verificación de cifrado AES-256).
19. El sitio web estático está publicado y accesible públicamente, conteniendo las 6 secciones especificadas.

9. Aprobación del Documento

Este documento debe ser revisado y aprobado formalmente por el stakeholder antes de iniciar la Fase 2 (Diseño del Sistema). La aprobación implica la aceptación explícita de los riesgos documentados en la Sección 7, en particular el riesgo R-01 (alcance completo bajo plazo ajustado).

Rol	Nombre	Firma / Aprobación	Fecha
Stakeholder / Cliente	Angel Luis Arreola Lopez	Acepte los riesgos, explicados por el Product Manager	21 de junio 2026
Product Manager	Claude	Valido Aprobación pero con posibles, riesgos.	21 de junio 2026

Fase 2

10. Propósito

Este documento traduce los requisitos aprobados en la Fase 1 (BRD/PRD v1.0) en una solución técnica concreta: arquitectura del sistema, modelo de datos, flujos de proceso y especificación de seguridad. Los diagramas de arquitectura, modelo de datos, flujo de escaneo y mockups de pantallas fueron presentados y visualizados en la sesión de trabajo; este documento los describe de forma textual y estructurada para su registro formal.

11. Arquitectura del sistema

La aplicación se implementa como una app Android nativa monolítica (Kotlin), sin backend propio, organizada en tres capas:

Capa	Responsabilidad	Componentes
Capa UI	Interacción con el usuario	Onboarding, escáner de QR, pantalla de resultado, historial, opciones
Capa de lógica de negocio	Procesamiento y reglas	Cliente API de VirusTotal, motor de clasificación de riesgo, detector de anomalías del navegador integrado (WebView instrumentado)
Capa de almacenamiento local	Persistencia cifrada	Historial de escaneos, lista negra, configuración (API Key cifrada AES-256)

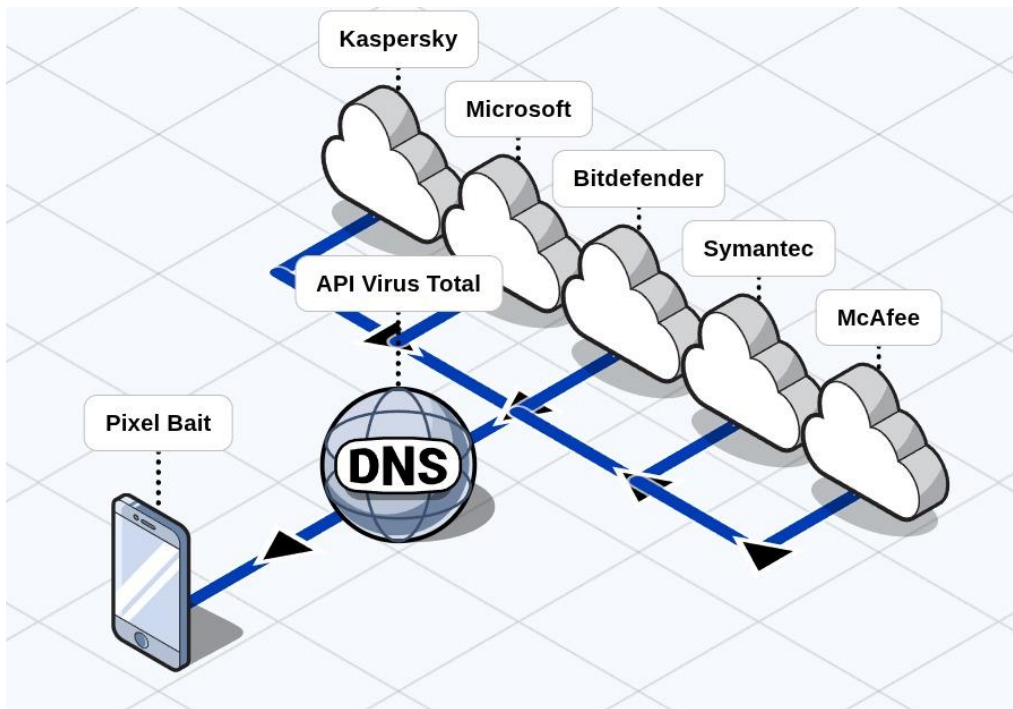


Ilustración 1

El único sistema externo con el que se comunica la aplicación es la API pública de VirusTotal, consumida directamente desde la capa de lógica de negocio mediante la API Key que cada usuario configura en el onboarding. No existe backend intermedio ni servidor propio del proyecto.

12. Modelado de datos (Almacenamiento Local)

No se requiere base de datos remota, ya que todo el almacenamiento es local. Se definen tres entidades: historial de escaneos, lista negra generada por el navegador integrado, y configuración de la app (donde reside la API Key cifrada).

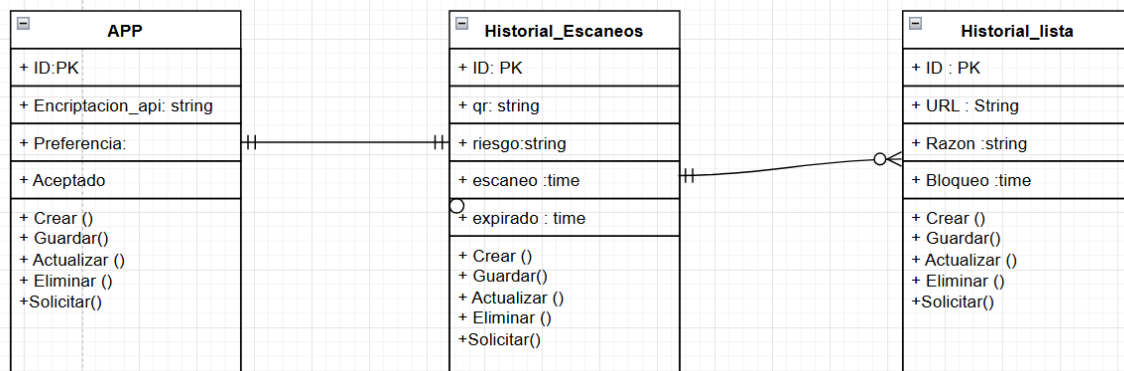


Ilustración 2

13. Flujo principal: Escaneo

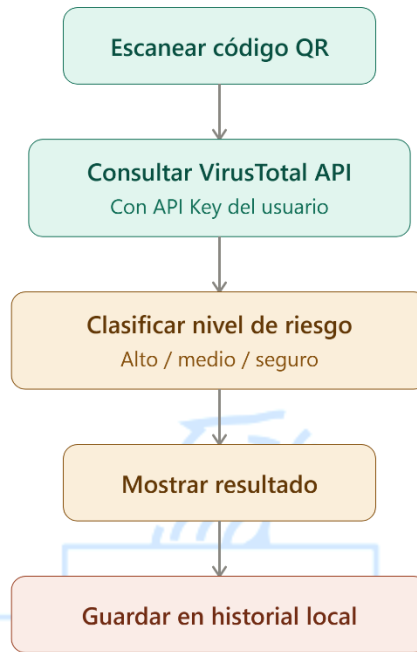


Ilustración 3

14. Mockup Visual - Pantallas principales

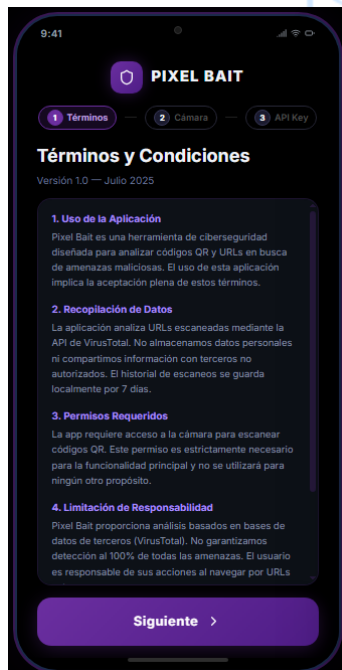


Ilustración 5

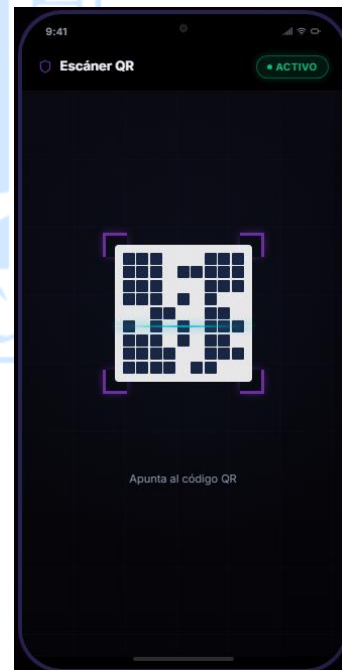


Ilustración 4



Ilustración 7



Ilustración 6

15.Stack Tecnológico

Componente	Tecnología	Versión exacta
Lenguaje de la app	Kotlin	2.0.21
IDE / Build system	Android Studio / Gradle (AGP)	Ladybug 2024.2.1 / AGP 8.7.2
SDK Android	minSdk / targetSdk	minSdk 26 (Android 8.0) / targetSdk 35 (Android 15)
Persistencia local	Room (sobre SQLite)	2.6.1
Cliente HTTP	Retrofit + OkHttp	Retrofit 2.11.0 / OkHttp 4.12.0
Serialización JSON	kotlinx.serialization	1.7.3
Cifrado / Keystore	AndroidX Security Crypto	1.1.0-alpha06

Escaneo de QR	ML Kit Barcode Scanning	17.3.0
Navegador integrado	android.webkit.WebView	Componente nativo del sistema Android
Tareas programadas	WorkManager	2.9.1
Sitio web estático	HTML5 / CSS3 / JavaScript	—
Hosting del sitio web	GitHub Pages (nivel gratuito)	—

15. Flujos principales

15.1 Flujo de Onboarding (RF-01 a RF-03)

1. Mostrar términos y condiciones → botón "Siguiente".
2. Solicitar permiso de cámara del sistema Android → botón "Siguiente".
3. Solicitar API Key de VirusTotal (con enlace de ayuda al sitio web si el usuario no la posee) → el botón "Siguiente" se habilita solo con clave válida ingresada.
4. Redirigir a la pantalla principal (escáner).

15.2 Flujo de Escaneo y Clasificación (RF-04 a RF-06)

5. El usuario escanea un código QR con la cámara.
6. La app envía la URL extraída a la API de VirusTotal usando la API Key del usuario.
7. El motor de clasificación evalúa la respuesta de los motores de detección y determina el nivel: Alto riesgo (≥ 3 motores marcan "malicious"), Riesgo Medio (1-2 motores marcan "suspicious" o "malicious"), o Seguro (sin coincidencias).
8. Se muestra una card visual con el resultado.
9. El resultado se guarda en SCAN_HISTORY con marca de tiempo de expiración a 7 días.

15.3 Flujo de Navegación Controlada y Detección de Anomalías (RF-07 a RF-11)

10. El usuario decide abrir la URL desde el navegador integrado (WebView instrumentado).
11. El WebView intercepta, en tiempo real: solicitudes de descarga de archivos, activación de la cámara del dispositivo y solicitudes de geolocalización, en todos los casos verificando si hubo consentimiento explícito del usuario.
12. Si se detecta cualquiera de estas acciones sin consentimiento, el WebView bloquea la carga y registra la URL en BLACKLIST_ENTRY.
13. En futuras visitas, cualquier URL presente en BLACKLIST_ENTRY se bloquea preventivamente antes de cargar.

16. Especificación de API – Peticiones a Virus Total

La app consume exclusivamente la API pública de VirusTotal v3, mediante tres tipos de petición HTTPS:

#	Momento	Método	Endpoint	Propósito
1	Al escanear un QR	POST	/api/v3/urls	Envía la URL para análisis. Header x-apikey. Cuerpo url= (form-urlencoded).
2	Tras el envío	GET	/api/v3/analyses/{id}	Sondeo (polling) del estado del análisis hasta status=completed.
3	Alternativa	GET	/api/v3/urls/{url_id}	Recupera un reporte ya existente por url_id (base64 de la URL sin padding).

Restricción a gestionar en Fase 3: la cuenta gratuita de VirusTotal limita a aproximadamente 4 solicitudes por minuto y 500 por día.